Reglas de detección de SOC Analyzer

Resumen detallado - basado en el código de la versión actual de la aplicación

La app detecta con **tres mecanismos** que se combinan: detectores de comportamiento (con umbrales), 18 reglas por patrón de evento y una correlación final que une los hallazgos en incidentes.

1. Detectores de comportamiento

Detector	Qué busca	Umbral y severidad
Fuerza bruta / spraying	Intentos de inicio de sesión fallidos agrupados por IP (o por usuario si no hay IP)	5 o más fallos en una ventana de 10 min. **Crítico** si hay un acceso exitoso desde esa IP o cuenta en las 2 h siguientes. **Alto** si hay 20 o más fallos, o spraying (una IP contra 5 o más cuentas). **Medio** en el resto. Los fallos que no alcanzan el umbral van a un hallazgo **Bajo** de "fallos aislados".
Origen inusual	Cuentas con IP habitual (5 o más sesiones y 70% o más desde una IP) que inician sesión desde una IP pública nueva	**Alto**
Múltiples orígenes externos	Una cuenta sin IP habitual con inicios exitosos desde 2 o más IP públicas	**Alto**
Acceso desde IP pública	Inicios exitosos desde una IP pública no habitual, no cubiertos por los casos anteriores	**Medio**
Fuera de horario	Inicios exitosos entre 22:00 y 06:00 o en fin de semana, solo si no es el patrón normal de la cuenta (menos del 50% de sus sesiones)	3 o más eventos: **Medio**. 1 o 2: se agrupan en un hallazgo **Bajo**.
Saltos entre equipos	Una cuenta con sesiones exitosas en 3 o más equipos distintos en 30 min	**Alto**
Exfiltración por volumen	Eventos de proxy con `bytes_out=`, agrupados por IP de origen	Más de 50 MB en total o 15 o más transferencias: **Crítico**
Webshell / ejecución web	Proceso `w3wp.exe` o usuario IIS AppPool ejecutando `cmd`, `powershell`, `whoami` y similares, o URL `.aspx`/`.ashx` con `webshell`; agrupado por equipo	**Crítico**

2. Reglas por patrón de evento (18)

Cada regla busca palabras clave o IDs de evento de Windows en el texto de la fila. Agrupa por usuario (o equipo/IP) y genera un hallazgo por grupo.

Categoría	Regla	Qué detecta	Sev.	MITRE
Escalamiento	Elevación de privilegios / cambio de grupos	4728, 4732, 4756, "added to admin", `localgroup administrators`, `runas`, UAC bypass	**Alto**	T1098
	Privilegios especiales asignados	4672	**Medio**	T1068
	Creación de cuenta	4720, `useradd`, `net user /add`	**Medio**	T1136
Fuerza bruta	Cuenta bloqueada	4740, lockout	**Medio**	T1110
Comandos	Robo de credenciales	mimikatz, sekurlsa, lsass, procdump, secretsdump	**Crítico**	T1003
	Shell inversa / C2	nc, ncat, meterpreter, cobalt strike, beacon	**Crítico**	T1059
	Destrucción de copias / ransomware	`vssadmin delete`, `wbadmin delete`, `cipher /w`, ransom	**Crítico**	T1486
	PowerShell ofuscado	`-enc`, DownloadString, IEX, `-nop`, `-w hidden`, bypass	**Alto**	T1059.001
	LOLBin	certutil urlcache, bitsadmin, mshta, regsvr32 scrobj	**Alto**	T1218

Categoría	Regla	Qué detecta	Sev.	MITRE
	Persistencia	`schtasks /create`, `sc create`, 7045, 4698, Run key	Alto	T1053
	Reconocimiento	whoami, `net user/group`, nltest, systeminfo, netstat	Medio	T1087
Mov. lateral	Ejecución remota	PsExec, WinRM, WMI, `admin$`, 4648	Alto	T1021
	Acceso remoto interno	RDP (tipo 10), mstsc; excluye fallos e IP públicas	Medio	T1021
Otras	Borrado de logs	1102, `wevtutil cl`, Clear-EventLog	Crítico	T1070
	Defensas deshabilitadas	Defender o antivirus desactivado	Alto	T1562
	Posible exfiltración (texto)	exfil, rclone, mega.nz, pastebin, FTP upload	Alto	T1041
	Malware / amenaza	malware, trojan, `.onion`, "amenaza"	Alto	T1204
	Escaneo / ataque web	nmap, masscan, sqlmap, UNION SELECT, `../..`, `<script>`	Medio	T1595

Las reglas ignoran cuentas de servicio y de máquina (SYSTEM, cuentas que terminan en `$`), salvo las de severidad Crítica.

3. Elevación por contexto

Si una cuenta o IP tuvo un acceso exitoso tras fuerza bruta (cuenta probablemente comprometida), sus otros hallazgos de severidad Media o Alta suben un nivel y se marcan con una flecha hacia arriba. La justificación lo explica en el propio hallazgo.

4. Correlación en incidentes

Los hallazgos se unen por cuentas e IP públicas compartidas, separando los que distan más de 12 h entre sí. Un grupo se vuelve **incidente** si abarca 2 o más categorías. Es **Crítico** si tiene 3 o más categorías o algún hallazgo Crítico.

5. Confianza y calidad de datos

Cada regla trae una confianza (Alta, Media o Baja), y sube un nivel si el hallazgo está en un incidente de 3 o más categorías. La app avisa si menos del 90% de los eventos tiene fecha válida, o menos del 50% tiene usuario o IP.

Limitaciones que debe conocer

- **Exfiltración por volumen:** solo lee el patrón `bytes_out=N`. Con otro formato de bytes no la detecta.
- **Falsos positivos:** las reglas buscan texto en toda la fila, así que palabras como "amenaza" o `lsass` pueden disparar un hallazgo sin ser un ataque real.
- **Mapeo MITRE:** la regla de copias de seguridad usa T1486 (cifrado), pero borrar shadow copies corresponde a T1490.
- **Umbrales fijos:** los valores (5 fallos en 10 min, 3 equipos en 30 min, 22:00-06:00, 50 MB) no se pueden configurar.
- **Nombres de equipo:** no normaliza `DC01` y `DC-01`, que cuentan como equipos distintos en los saltos.
- **Lo que no detecta hoy:** ejecución periódica de un mismo programa (persistencia o beacon), acceso masivo a archivos (recolección de datos), reputación de IP, ni listas de excepciones del cliente.

Mejoras sugeridas: normalizar equipos, umbrales configurables, detección de recolección y ejecución periódica, y el mapeo T1490.